



Politécnico
Internacional

ASEGURAMIENTO DE INFRAESTRUCTURA DE REDES Y SISTEMAS

**“La ciberseguridad no se alcanza, se mantiene.
Es una carrera constante contra el cambio.”**

- ☐ Infraestructura de Gestión de Privilegios (PAM)
- ☐ Certificados Digitales
- ☐ Ciclo de Vida de un Certificado Digital
- ☐ Fuente de Autoridad y Sub Authority (CA raíz y subordinada)
- ☐ Verificación de Privilegios en Certificados
- ☐ DAC – Discretionary Access Control
- ☐ PKI – Public Key Infrastructure
- ☐ MFA – Autenticación Multifactor
- ☐ 2FA – Autenticación de Dos Factores
- ☐ Token – Medio de autenticación físico o digital
- ☐ OTP – Contraseña de un solo uso (TOTP/HOTP)
- ☐ Tabla comparativa de software libre: PrivacyIDEA, FreeIPA, OpenSSL, Keycloak, LinOTP, etc.

Infraestructura de Gestión de Privilegios

Son un conjunto de políticas, procesos y tecnologías diseñadas para controlar, monitorear y asegurar el uso de cuentas con privilegios elevados dentro de una organización. Su objetivo es minimizar los riesgos asociados al acceso privilegiado a sistemas críticos.

Características clave:

- Controla y registra el uso de cuentas privilegiadas (como administradores, root, etc.).
- Implementa el principio de menor privilegio (solo se otorgan los permisos necesarios).
- Puede incluir autenticación multifactor, rotación automática de contraseñas, y sesiones auditadas.
- Detecta accesos no autorizados o comportamientos anómalos.
- Integra con sistemas de SIEM y directorios como Active Directory o LDAP.



Certificados Digitales

Archivo electrónico que utiliza criptografía de clave pública para autenticar la identidad de un usuario, dispositivo o entidad, y garantizar la integridad y confidencialidad de la información transmitida. Está firmado digitalmente por una Autoridad Certificadora (CA).

Características clave:

- Contiene la clave pública del titular, datos de identificación y la firma de la CA.
- Utiliza estándares como X.509.
- Su validez depende de la confianza en la CA emisora.
- Tiene un periodo de vigencia y puede ser revocado.
- Se usa en protocolos como HTTPS, S/MIME, VPNs, y firmas digitales..



Ciclo de Vida de Un Certificado Digital

Conjunto de etapas que atraviesa un certificado digital desde su creación hasta su expiración o revocación. Cada etapa debe ser gestionada correctamente para garantizar la seguridad y validez de la comunicación digital.

Etapas del ciclo de vida:

- **Generación del par de claves:** Se generan una clave pública y una privada.
- **Solicitud de certificado (CSR):** Se crea una solicitud firmada que se envía a una Autoridad Certificadora (CA).
- **Emisión:** La CA valida la identidad y emite el certificado digital.
- **Distribución e instalación:** El certificado se instala en el servidor, dispositivo o software correspondiente.
- **Uso:** Se utiliza para autenticación, cifrado o firma digital.
- **Renovación:** Antes de que expire, se puede solicitar una renovación para continuar el servicio sin interrupciones.
- **Revocación:** Puede ser revocado anticipadamente si se compromete la clave privada o cambia la información del titular.
- **Expiración:** Finaliza la vigencia del certificado y deja de ser válido.



Root Authority | Subordinate CA

En una infraestructura de clave pública (PKI), la Fuente de Autoridad o Autoridad Raíz (**Root CA**) es la entidad certificadora principal y de mayor confianza que emite certificados digitales para otras autoridades subordinadas. Las Sub Autoridades o Autoridades Subordinadas (**Sub CAs**) reciben su certificado de la Root CA y pueden emitir certificados digitales a usuarios, dispositivos o servicios. Características clave:

Root Authority (CA raíz)

- Es la raíz de la cadena de confianza.
- Firma su propio certificado (autofirmado).
- Está altamente protegida y raramente se usa directamente para emitir certificados a usuarios finales.
- Su compromiso compromete toda la cadena de confianza.

Sub Authority (CA subordinada)

- Recibe su certificado de la Root CA.
- Puede estar especializada (por ejemplo, para firmar certificados de usuario, SSL o de firma de código).
- Permite escalar y distribuir la gestión de certificados.
- Puede ser revocada sin afectar toda la infraestructura.



Root Authority | Subordinate CA

Ejemplo

En una gran empresa, la Root CA se mantiene offline por seguridad. Una Sub CA interna, autorizada por la Root, emite certificados digitales para los empleados que se conectan a la VPN corporativa. Si la Sub CA es comprometida, puede revocarse sin afectar la integridad de la Root CA ni del resto de la organización.



Procesos de Verificación de Privilegios en Certificados Digitales

Es el procedimiento mediante el cual un sistema valida los derechos o privilegios asociados a un certificado digital antes de permitir el acceso a recursos, servicios o la ejecución de acciones críticas. Involucra la validación del certificado y la interpretación de sus extensiones y atributos.

Características clave:

- **Validación de la cadena de confianza:** Se verifica que el certificado haya sido emitido por una CA confiable.
- **Revisión de vigencia y revocación:** Se comprueba la fecha de expiración y si el certificado ha sido revocado (usando CRL u OCSP).
- **Verificación de extensiones:** Se analizan campos como: Key Usage (ej. cifrado, firma digital) Extended Key Usage (ej. autenticación de servidor, firma de código) Subject Alternative Name (identidades adicionales)
- **Asignación de roles o permisos:** Algunos sistemas usan certificados para mapear identidades a roles específicos definidos en políticas de acceso (RBAC).
- **Integración con sistemas de control de acceso:** Como Active Directory, LDAP o sistemas PAM (Privileged Access Management).



Procesos de Verificación de Privilegios en Certificados Digitales

Ejemplo:

Un servidor web protegido por un firewall requiere que los usuarios se autenticuen con certificados digitales emitidos por una Sub CA interna. Al conectarse, el servidor valida la cadena de confianza, verifica que el campo Key Usage permite autenticación de cliente, y que el certificado no esté en la CRL. Si todo es válido, se concede acceso al sistema de gestión administrativa según el rol definido.



DAC – Discretionary Access Control (Control de Acceso Discrecional)

Modelo de control de acceso en el que el propietario de un recurso (archivo, directorio, base de datos, etc.) tiene la autoridad para decidir quién puede acceder a ese recurso y qué tipo de operaciones puede realizar (lectura, escritura, ejecución, etc.). Las decisiones de acceso son determinadas por permisos asociados directamente a los objetos y usuarios.

Características clave:

- Basado en la identidad del usuario o grupo.
- El propietario del recurso define los permisos.
- Flexibilidad alta, pero con mayor riesgo si no se gestiona correctamente.
- Común en sistemas operativos como UNIX/Linux (permisos rwx) y Windows NTFS.
- No impide que un usuario con acceso autorizado comparta el recurso con otros.



DAC – Discretionary Access Control (Control de Acceso Discrecional)

Ejemplo:

En un servidor Linux, el usuario profesor crea un archivo llamado examen.txt y otorga permisos de lectura y escritura solo a su grupo de docentes (grupo_docentes). Como profesor es el dueño del archivo, puede cambiar estos permisos en cualquier momento usando el comando `chmod`.

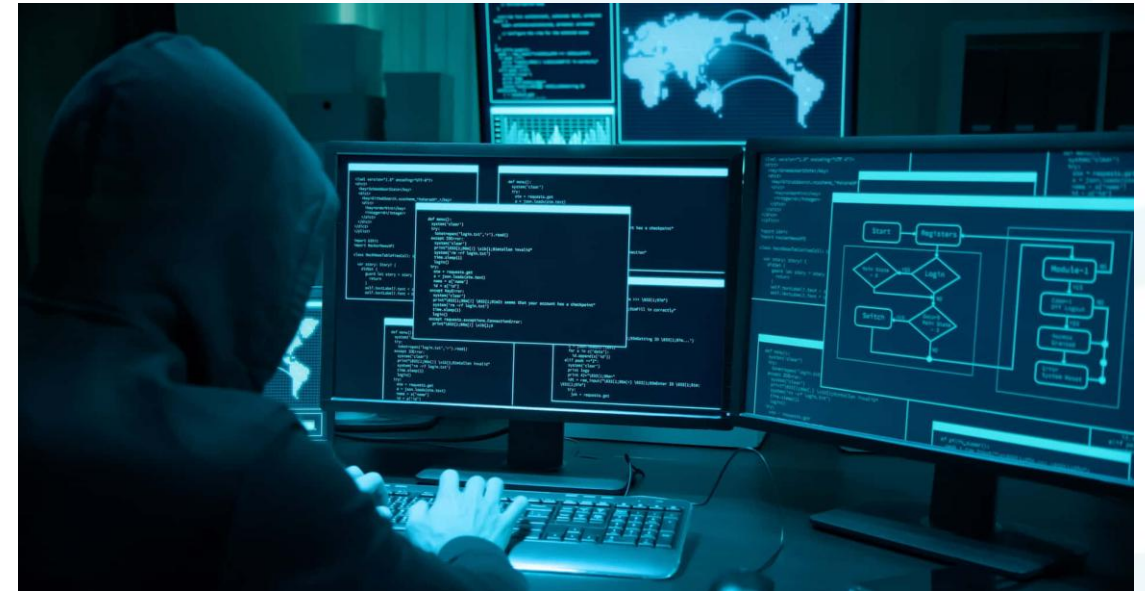


PKI – Public Key Infrastructure (Infraestructura de Clave Pública)

Conjunto de tecnologías, políticas, procedimientos y entidades que permiten la creación, gestión, distribución, uso, almacenamiento y revocación de certificados digitales y claves criptográficas. La PKI habilita el uso seguro de la criptografía de clave pública para garantizar autenticación, confidencialidad, integridad y no repudio en entornos digitales. Características clave: Usa un par de claves: **clave pública** (para cifrar/verificar) y **clave privada** (para descifrar/firmar).

Está compuesta por:

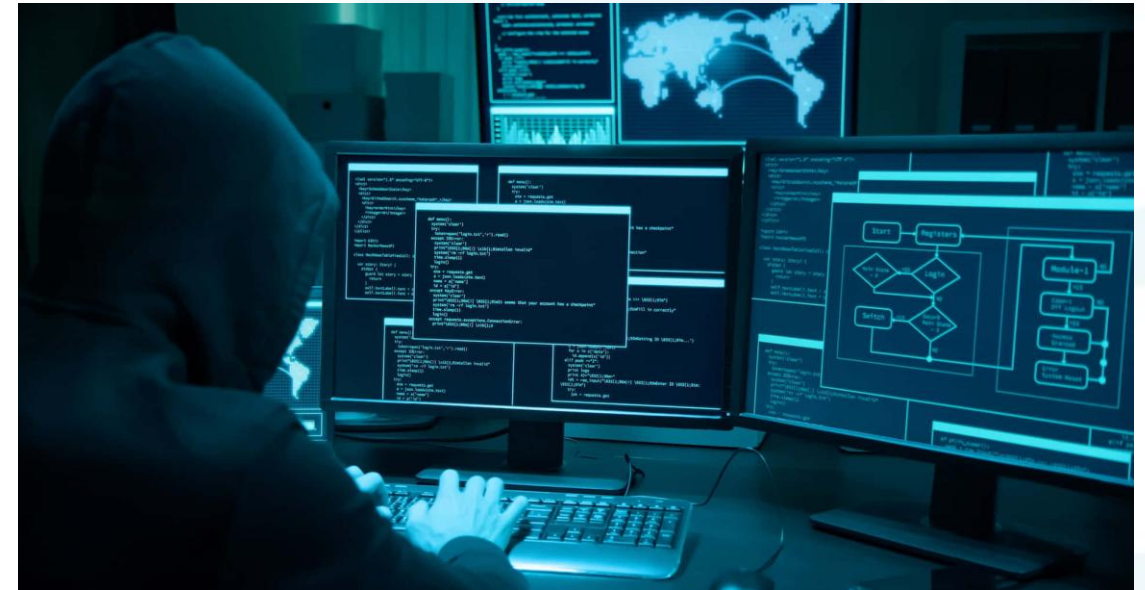
- Autoridades Certificadoras (CAs)
- Autoridades de Registro (RA)
- Repositorios de certificados
- Listas de Revocación (CRL) / OCSP
- Permite la emisión de certificados digitales para usuarios, dispositivos, servidores o software.
- Utiliza estándares como X.509, RSA, SHA-256, entre otros.
- Fundamental para protocolos como HTTPS, S/MIME, VPNs, y firmas digitales.



PKI – Public Key Infrastructure (Infraestructura de Clave Pública)

Ejemplo:

Una universidad implementa una PKI interna para firmar digitalmente los certificados académicos de sus egresados. El certificado digital de cada estudiante es emitido por una CA institucional, permitiendo validar la autenticidad del documento en línea mediante la firma digital y el uso de la clave pública publicada por la CA



MFA – Multifactor Authentication (Autenticación Multifactor)

Mecanismo de seguridad que requiere que un usuario proporcione dos o más factores de autenticación independientes para verificar su identidad al acceder a un sistema, aplicación o servicio. Su propósito es reducir significativamente el riesgo de accesos no autorizados, incluso si una de las credenciales es comprometida. Características clave:

Utiliza factores de distintos tipos.

Algo que sabes: contraseña, PIN.

Algo que tienes: token físico, app de autenticación, tarjeta inteligente.

Algo que eres: biometría (huella, rostro, retina).

Aumenta la seguridad de autenticación exponencialmente frente a métodos tradicionales (solo contraseña).

Se implementa comúnmente en accesos remotos, banca digital, correo institucional y VPNs.

Puede incluir autenticación adaptativa (según el contexto del usuario).



MFA – Multifactor Authentication (Autenticación Multifactor)

Ejemplo:

Un administrador de red accede al panel de configuración del firewall empresarial. Primero ingresa su contraseña (algo que sabe), luego debe aprobar el acceso desde su celular a través de un código temporal generado por Google Authenticator (algo que tiene). Si uno de los factores se ve comprometido, el sistema sigue siendo seguro.



Token

Un token es un dispositivo físico o digital que genera o almacena credenciales de autenticación, utilizado como parte de un sistema de seguridad para verificar la identidad de un usuario. Los tokens pueden ser parte de esquemas de autenticación como 2FA o MFA. Características clave:

Puede ser:

Físico: dispositivos USB, tarjetas inteligentes (smartcards), llaveros OTP.

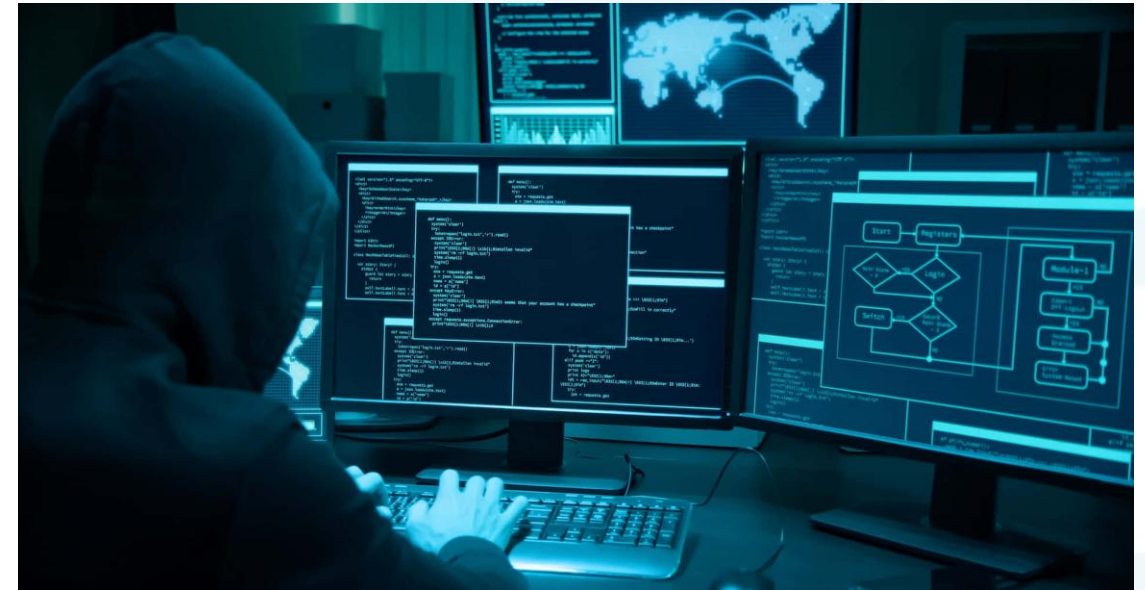
Digital: aplicaciones como Google Authenticator, Microsoft Authenticator, tokens OTP por SMS o email.

Frecuentemente generan códigos de un solo uso (OTP – One Time Password).

Pueden tener tiempo limitado de validez (ej. 30 segundos).

Algunos tokens usan criptografía para firmar digitalmente operaciones (ej. tokens de firma).

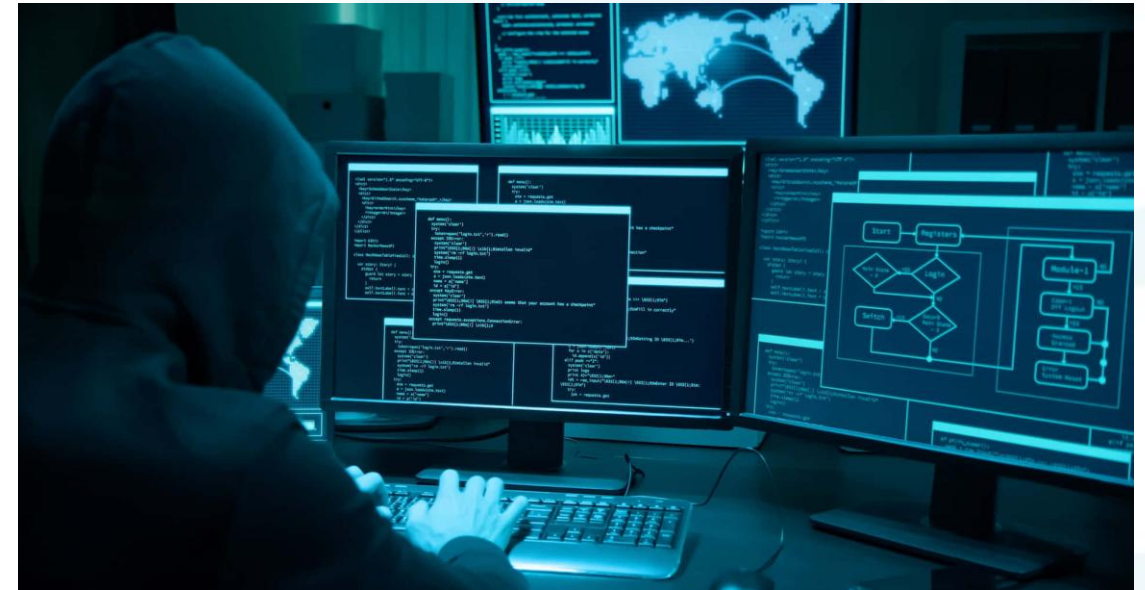
No almacenan contraseñas directamente; generan datos que se validan con un servidor.



Token

Ejemplo:

Un administrador accede a un sistema bancario usando un token USB criptográfico. Al insertarlo, el sistema solicita el PIN del token para desbloquearlo y permitir la firma digital de transacciones de alto valor.



OTP – One-Time Password (Contraseña de un Solo Uso)

Contraseña generada automáticamente que solo es válida para una única sesión o transacción. Generalmente se utiliza como segundo factor de autenticación en esquemas de seguridad como 2FA o MFA, y su valor cambia cada vez que se genera o en intervalos de tiempo definidos.

Características clave:

- Validez limitada en el tiempo (ej. 30 segundos) o por una sola transacción.
- Generado mediante algoritmos como:
 - TOTP (Time-based OTP): basado en tiempo.
 - HOTP (HMAC-based OTP): basado en contador de eventos.

Puede enviarse por:

- SMS
- Correo electrónico
- Aplicaciones autenticadoras (Google Authenticator, Authy, etc.)
- Reduce el riesgo de reutilización de credenciales robadas.
- Su uso no requiere que el usuario memorice la contraseña.



SOFTWARE

Nombre	URL	Licencia	Funcionalidad principal	Categoría(s)
FreeIPA	https://www.freeipa.org/	GPLv3	Solución completa de identidad con soporte para certificados, DAC, LDAP y Kerberos.	Certificados, DAC
PrivacyIDEA	https://www.privacyidea.org/	AGPLv3	Servidor de autenticación OTP, tokens, 2FA y MFA con gestión centralizada.	OTP, Token, MFA, 2FA
OpenOTP	https://www.rcdevs.com/openotp/	Gratuito con código abierto (Community)	Framework de autenticación compatible con LDAP/AD, soporta OTP, tokens y MFA.	OTP, MFA, 2FA
LinOTP	https://www.linotp.org/	AGPLv3	Servidor OTP modular con backend en Python, integración con AD y LDAP.	OTP, Token
OpenSSL	https://www.openssl.org/	Apache 2.0	Librería criptográfica para generación y gestión de certificados X.509.	Certificados Digitales
Keycloak	https://www.keycloak.org/	Apache 2.0	Gestión de identidades y accesos con soporte para MFA, OTP y tokens.	MFA, 2FA, Token
Authy (CLI)	https://github.com/authy/authy-ssh	MIT	Herramienta para usar OTP/2FA en conexiones SSH usando tokens.	OTP, 2FA
Sudo y chmod	https://www.gnu.org/software/coreutils/	GPL	Control de permisos y privilegios de acceso discrecional (DAC).	DAC
SoftHSM	https://github.com/opensnsec/SoftHSMv2	BSD	Implementación de un HSM software para gestión segura de claves y certificados.	Certificados Digitales, Token

CONCLUSIONES